

Security Audit Report

User ID: 14

Key Findings

Finding #1

Weakness: Missing control for: Are third-party vendors assessed for cybersecurity risks?

Severity: High

Recommendation: Assess third-party vendors for cybersecurity risks.

Compliance Mapping:

- A.15 Supplier Relationships
- SR-3 Supply Chain Controls
- Requirement 12.8 Service Provider Management
- CC9 Vendor Risk Management
- Article 28 Processor Security
- 164.308(b) Business Associate Contracts
- APO10 Manage Suppliers

Finding #2

Weakness: Missing control for: Do employees receive regular cybersecurity awareness training?

Severity: Medium

Recommendation: Conduct regular cybersecurity awareness training.

Compliance Mapping:

- A.7 Human Resource Security
- AT-2 Security Awareness Training
- Requirement 12.6 Security Awareness Program
- CC2 Communication and Information
- Article 39 Staff Awareness
- 164.308(a)(5) Security Awareness and Training
- APO07 Manage Human Resources

Finding #3

Weakness: Missing control for: Are user access rights reviewed periodically?

Severity: High

Recommendation: Perform periodic user access reviews.

Compliance Mapping:

- A.9 User Access Management
- AC-2 Account Management
- Requirement 7 - Restrict Access to Need-to-Know
- CC6 Access Review Controls
- Article 32 - Controlled Access
- 164.308(a)(4) Access Authorization
- DSS05 Identity and Access Management

Finding #4

Weakness: Missing control for: Are firewall rules reviewed and updated regularly?

Severity: High

Recommendation: Review firewall rules regularly and remove unnecessary access.

Compliance Mapping:

- A.13 Network Security Management
- SC-7 Boundary Protection
- Requirement 1 - Install and Maintain Firewall Configuration
- CC6 Network Controls
- Article 32 - Network Protection
- 164.312(c) Integrity Controls
- DSS05 Security Monitoring

Finding #5

Weakness: Missing control for: Do you enforce strong password policy with expiry and complexity rule

Severity: High

Recommendation: Implement strong password policy with expiry and complexity rules.

Compliance Mapping:

- A.9 Access Control
- IA-5 Authenticator Management
- Requirement 8 - Password Security
- CC6 Access Security
- Article 32 - Access Protection
- 164.308(a)(5) Password Management
- DSS05 Security Management

Finding #6

Weakness: Missing control for: Do you use Multi-Factor Authentication for admin and remote access?

Severity: High

Recommendation: Enable MFA for all admin and remote access accounts.

Compliance Mapping:

- A.9 Access Control
- IA-2 Identification and Authentication
- Requirement 8 - Identify and Authenticate Access
- CC6 Logical and Physical Access Controls
- Article 32 - Security of Processing
- 164.312(d) Person or Entity Authentication
- DSS05 Manage Security Services